

WP2 Multi-Sig 根金鑰與多方託管政策

版本：初稿 v0.1.1 (非生產規格)

日期：2026-08-13

對應：憲章 v0.3.4 第 19 條第 4 款、第 4 條、附錄 D

狀態：給工程 / 安全團隊的工作起點，非正式法律、非生產規格。

建立可驗證、可審計、抗單點的根金鑰治理，使量產簽名權、BMC / 韌體解鎖權、緊急熔斷權與恢復授權無法被單一控制面挾持，並與能力熔斷狀態機 (WP3) 完整對接。

1. 目的

把憲章的多方託管寫成可執行政策：根信任可驗證、可替換、可熔斷；任何單一實體不得單獨持有或單獨恢復根。

2. 中立聲明 (必須置於文件開頭)

本政策不指定、不預設任何特定商業實體、政治團隊、國家或個人為全球唯一或永久合法操作者。任何組織僅得依公開程序、以可替換託管方身分參與。本政策禁止將根金鑰治理解釋為任何具名主體的憲章層級專屬主權。

3. 核心架構原則

- 採用公開的 M-of-N 多簽名。
- 門檻與成員類型可公開驗證 (成員真實身分可在合法隱私範圍內部分遮蔽，但權重與角色類型不可隱藏)。
- 同一公司集團、同一政府或同一利益聯盟所控制的簽名權重，不得單獨達到可獨斷通過日常根操作的門檻；上限必須公開寫死並定期重算。
- 至少跨多個地理 / 法域設置實體託管節點。
- 根種子 / 根 CA 必須透過多方見證的線下冷儲存儀式 (或等效高保證離線程序) 生成與分片。禁止以單一雲端帳號或單一軟體熱錢包作為根。冷錢包 / 離線保管是要求；熱錢包是被禁止的根持有方式，不是建議。

4. 門檻分層 (強制)

操作類型	門檻要求	備註
日常量產簽名	較低 M-of-N，仍須跨至少兩類利益方	允許較高效率
BMC / 韌體解鎖	中高 M-of-N	階段 0 硬性條件
緊急能力熔斷	高門檻，或預先授權的條件式熔斷政策	可快速觸發
自熔斷狀態恢復	最高門檻，強制跨法域 + 跨利益方	禁止任何自動恢復

5. 可替換硬機制 (必須寫入政策)

- 所有託管方必須有明確任期。
- 撤換條件、繼承規則、緊急替換程序必須預先定義並公開。
- 獨立審計方定期驗證「實質可替換性」。
- 禁止任何形式的永久既得利益或不可撤銷地位。

6. 線下儀式最低標準

- 根種子生成必須有多方實體現場 (或等效高保證) 見證。
- 分片後加密，並分散存放於不同法域 / 地理位置的冷儲存 (離線、非熱端)。
- 完整儀式紀錄摘要 (可公開部分) 必須留存並可審計。
- 禁止單一主體持有可單獨恢復根的完整備份。
- 再次確認：根不是熱錢包；單一軟體熱錢包、單一雲端 KMS 帳號、單一線上種子備份，均不得作為根。

7. 與能力熔斷 (WP3) 的強制對接

- 頻率評估器或安全監控觸發低頻 / 影子控制面時，必須能進入能力熔斷。
- 自 LOCK / EVIDENCE 狀態恢復至 NORMAL，唯一合法路徑為本政策規定的最高門檻多簽授權。
- 任何試圖繞過多簽的恢復行為，本身視為控制面入侵。

8. 階段適用（與憲章一致）

- 階段 0：新部署高算力訓練 / 推論伺服器及其 BMC / 帶外管理 → 量產簽名納入 Multi-Sig · BMC 多簽解鎖與審計為硬性條件。
- 階段 1：邊緣高算力與關鍵基礎設施節點 → 同上，並強化資產台帳與營運責任歸因。
- 階段 2：更廣裝置類別 → 以合規標章與採購門檻推進，不要求全球存量瞬間換根。

9. 必備公開產出物

- ☐ 本政策正式文件
- ☐ 成員角色類型與權重規則（可部分遮蔽真實身分）
- ☐ 憑證與吊銷清單的發布通道
- ☐ 熔斷與恢復 runbook（與 WP3 狀態機一致）
- ☐ 階段 0 / 1 合規標章標準
- ☐ 可替換性審計週期與報告範本

10. 非目標（明確不做）

- 不設立任何具名全球硬體主權
- 不授權取代各國合法司法
- 不將預設處置設為大規模自動物理銷毀
- 不要求在無供應鏈協商下接管已出廠全部晶片

結束。對應憲章 v0.3.4；機制中立。硬約束不得弱化。